



ΠΑΝΕΠΙΣΤΗΜΙΟ
ΔΥΤΙΚΗΣ ΑΤΤΙΚΗΣ
UNIVERSITY OF WEST ATTICA

ΤΜΗΜΑ ΜΗΧΑΝΙΚΩΝ ΠΛΗΡΟΦΟΡΙΚΗΣ ΚΑΙ
ΥΠΟΛΟΓΙΣΤΩΝ

ΕΡΓΑΣΙΑ 5
TLS SCANNING

ΣΤΟΙΧΕΙΑ ΦΟΙΤΗΤΗ

ΟΝΟΜΑΤΕΠΩΝΥΜΟ : ΑΘΑΝΑΣΙΟΥ ΒΑΣΙΛΕΙΟΣ ΕΥΑΓΓΕΛΟΣ

ΑΡΙΘΜΟΣ ΜΗΤΡΩΟΥ : 19390005

ΕΞΑΜΗΝΟ ΦΟΙΤΗΤΗ : 8^ο

ΚΑΤΑΣΤΑΣΗ ΦΟΙΤΗΤΗ : ΠΡΟΠΤΥΧΙΑΚΟ

ΠΡΟΓΡΑΜΜΑ ΣΠΟΥΔΩΝ : ΠΑΔΑ

ΤΜΗΜΑ ΕΡΓΑΣΤΗΡΙΟΥ : ΑΣΦ 05 ΤΕΤΑΡΤΗ 12:00 – 14:00

ΥΠΕΥΘΥΝΟΣ ΕΡΓΑΣΤΗΡΙΟΥ : ΓΕΩΡΓΟΥΛΑΣ ΑΓΓΕΛΟΣ

ΗΜΕΡΟΜΗΝΙΑ ΠΑΡΑΔΟΣΗΣ : 18/6/2023

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

ΦΩΤΟΓΡΑΦΙΑ ΦΟΙΤΗΤΗ :



ΠΕΡΙΕΧΟΜΕΝΑ

<u>Περιβάλλον Εργαστηρίου</u>	(ΣΕΛΙΔΑ 4)
<u>1. TLS Scanning σε ηλεκτρονικά καταστήματα</u>	(ΣΕΛΙΔΕΣ 5 – 10)
Ιστοσελίδα	(ΣΕΛΙΔΑ 5)
Έρευνα από το web εργαλείο	(ΣΕΛΙΔΕΣ 5 – 8)
Έρευνα από το εγκατεστημένο εργαλείο	(ΣΕΛΙΔΕΣ 8 – 9)
Συμφωνίες και διαφωνίες των εργαλείων	(ΣΕΛΙΔΑ 10)
<u>2. TLS Scanning σε ειδησεογραφικά sites</u>	(ΣΕΛΙΔΕΣ 10 – 17)
Ιστοσελίδα	(ΣΕΛΙΔΑ 10)
Έρευνα από το web εργαλείο	(ΣΕΛΙΔΕΣ 1 – 15)
Έρευνα από το εγκατεστημένο εργαλείο	(ΣΕΛΙΔΕΣ 15 – 16)
Συμφωνίες και διαφωνίες των εργαλείων	(ΣΕΛΙΔΑ 17)
<u>3. TLS Scanning σε sites Πανεπιστημίων</u>	(ΣΕΛΙΔΕΣ 17 – 24)
Ιστοσελίδα	(ΣΕΛΙΔΑ 17)
Έρευνα από το web εργαλείο	(ΣΕΛΙΔΕΣ 18 – 22)
Έρευνα από το εγκατεστημένο εργαλείο	(ΣΕΛΙΔΕΣ 22 – 23)
Συμφωνίες και διαφωνίες των εργαλείων	(ΣΕΛΙΔΑ 24)
<u>4. TLS Scanning ύποπτης ιστοσελίδας</u>	(ΣΕΛΙΔΕΣ 24 – 30)
Ιστοσελίδα	(ΣΕΛΙΔΑ 24)
Έρευνα από το web εργαλείο	(ΣΕΛΙΔΕΣ 25 – 29)
Έρευνα από το εγκατεστημένο εργαλείο	(ΣΕΛΙΔΕΣ 29 – 30)
Συμφωνίες και διαφωνίες των εργαλείων	(ΣΕΛΙΔΑ 30)

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

ΔΡΑΣΤΗΡΙΟΤΗΤΕΣ

Περιβάλλον Εργαστηρίου

Οι δραστηριότητες εκτελέστηκαν σε εικονική μηχανή του Linux και συγκεκριμένα στην έκδοση Ubuntu22.04. Τα εργαλεία που χρησιμοποιήθηκαν για να ανιχνεύσουν τυχόν ευπάθειες ως προς το πρωτόκολλο TLS που υποστηρίζει μία ιστοσελίδα, είναι :

1. <https://www.ssllabs.com/ssltest/> το οποίο είναι web εργαλείο
2. <https://linuxsecurity.expert/security-tools/ssltls-scanners> το A2SV εργαλείο που είναι ένα python2 script που ανιχνεύει μέσω βιβλιοθηκών της python2, τυχόν ευπάθειες μίας ιστοσελίδας ως προς το πρωτόκολλο TLS

SSL/TLS scanners

Tools

Popular SSL/TLS scanners

A2SV (SSL vulnerability scanner)

vulnerability scanning, vulnerability testing

A2SV is short for Auto Scanning to SSL Vulnerability, a security tool to scan for SSL and TLS vulnerabilities. It can be used during security assessments.

CRIME

DROWN

FREAK

HeartBleed

LOGJAM

Η εντολή που εκτελείται για την έρευνα της ιστοσελίδας από το εγκατεστημένο εργαλείο είναι

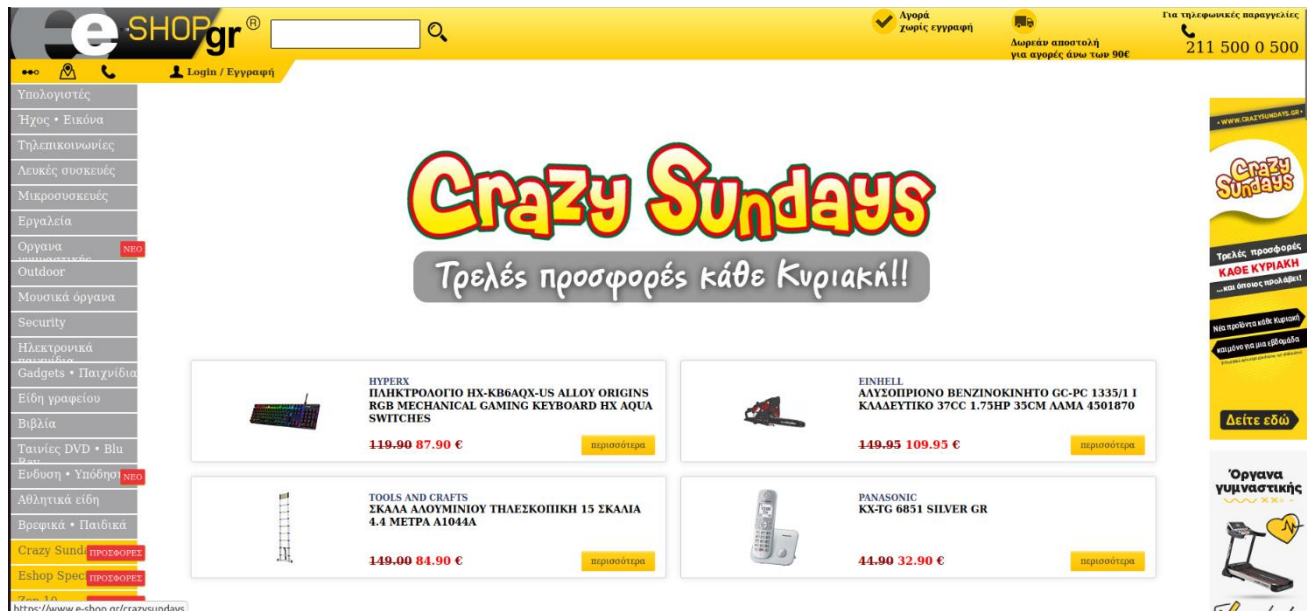
```
python2 a2sv.py -t IP Adress
```

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

1. TLS Scanning σε ηλεκτρονικά καταστήματα

Ιστοσελίδα

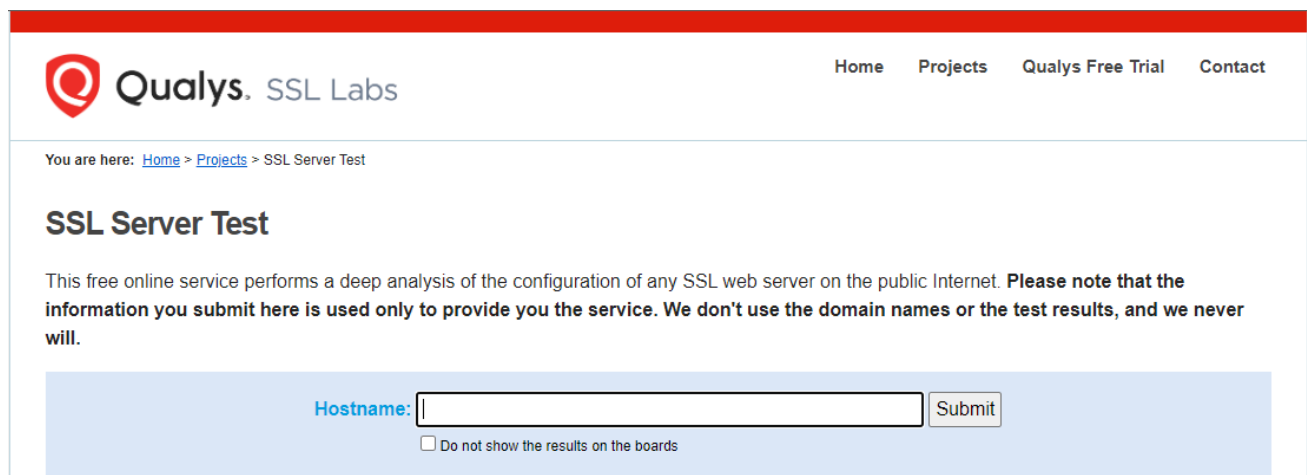
Για την ανάγκη της δραστηριότητας χρησιμοποιήθηκε το site <https://www.e-shop.gr/> ηλεκτρονικού καταστήματος, προκειμένου να ελεγχθεί ως προς την αξιοπιστία του στο πρωτόκολλο TLS.



Εικόνα 1.1. Η ιστοσελίδα ηλεκτρονικού καταστήματος e-shop

Έρευνα από το web εργαλείο

Αρχικά, χρησιμοποιήσαμε το web εργαλείο <https://www.ssllabs.com/ssltest/>.



Εικόνα 1.2. Το web εργαλείο SSL Labs

Βάλαμε το URL της ιστοσελίδας στο πεδίο Hostname που παρέχει το εργαλείο και είδαμε τα αποτελέσματα της έρευνας και τα ψηφιακά πιστοποιητικά της ιστοσελίδας στο <https://www.ssllabs.com/ssltest/analyze.html?d=www.e-shop.gr>.

You are here: [Home](#) > [Projects](#) > [SSL Server Test](#) > www.e-shop.gr

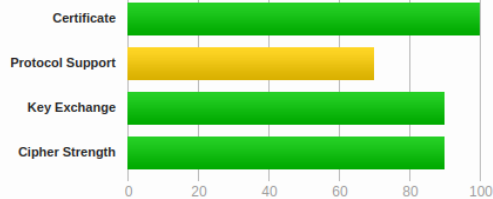
SSL Report: www.e-shop.gr (80.245.171.70)

Assessed on: Sun, 18 Jun 2023 10:22:39 UTC | [Clear cache](#)

[Scan Another »](#)

Summary

Overall Rating



Visit our [documentation page](#) for more information, configuration guides, and books. Known issues are documented [here](#).

This server supports TLS 1.0 and TLS 1.1. Grade capped to B. [MORE INFO »](#)

DNS Certification Authority Authorization (CAA) Policy found for this domain. [MORE INFO »](#)

Εικόνα 1.3. Τα αποτελέσματα της έρευνας του web εργαλείου

Certificate #1: RSA 2048 bits (SHA256withRSA)	
 Server Key and Certificate #1	
Subject	www.e-shop.gr Fingerprint SHA256: 28398d5b8f789f73aa9b84423b12c26dea1de24e39d519d91d8cc7e5d99c3b Pin SHA256: i3GmQ97LINSleEHkYwCPLRGjaWYb5MdFRYOKHsIO=
Common names	www.e-shop.gr
Alternative names	www.e-shop.gr e-shop.gr
Serial Number	05b43e3234497953d7b964f2977cf2fc
Valid from	Sun, 27 Nov 2022 00:00:00 UTC
Valid until	Wed, 29 Nov 2023 23:59:59 UTC (expires in 5 months and 11 days)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	Sectigo RSA Domain Validation Secure Server CA AIA: http://crt.sectigo.com/SectigoRSADomainValidationSecureServerCA.crt
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	OCSP OCSP: http://ocsp.sectigo.com
Revocation status	Good (not revoked) Yes policy host: e-shop.gr issue: digicert.com flags:0 issue: letsencrypt.org flags:0 issue: comodoca.com flags:0 issue: sectigo.com flags:0
DNS CAA	
Trusted	Yes Mozilla Apple Android Java Windows

Εικόνα 1.4. Το ψηφιακό πιστοποιητικό του server

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Η έρευνα έδειξε ότι ο βαθμός αξιοπιστίας της ιστοσελίδας ως προς το πρωτόκολλο TLS είναι «B» που σημαίνει ότι παρουσιάζει ευπάθεια και συγκεκριμένα στο «Protocol Support» που είναι με κίτρινο χρώμα (σε αντίθεση με τα άλλα που είναι πράσινα στο ραβδόγραμμα δίπλα από τον βαθμό). Αναζητήσαμε περισσότερες πληροφορίες στο πεδίο που λέει :

“The server supports TLS 1.0 and TLS 1.1. Grade capped to B. MORE INFO”

και συγκεκριμένα στο άρθρο https://blog.qualys.com/product-tech/2017/03/13/caa-mandated-by-cabrowser-forum?_ga=2.204699411.2017122474.1687046115-1545449628.1687046115

SSL Labs Grade Change for TLS 1.0 and TLS 1.1 Protocols



Yash Sannegowda

November 19, 2018 - 4 min read

👍 49

Last updated on: December 16, 2022



Update 1/31/2020: The grade change is now live on www.ssllabs.com. Servers that support TLS 1.0 or TLS 1.1 are capped to B grade.

Update 1/16/2020: The grade change is now live on the development server at dev.ssllabs.com. Servers that support TLS 1.0 or TLS 1.1 are capped to B grade on the development server. Deployment to production SSL Labs servers is planned for the very end of January.

Update 10/11/19: The TLS 1.0/1.1 warning changes are now live on www.ssllabs.com. The grade change for supporting TLS 1.0/1.1 is changed from March 2020 to January 2020 as shown below in the “SSL Labs Grade Change” section below and as reflected in the summary messages in SSL Labs results.

Update 11/30/18: Now live on ssllabs.com: In Configuration->Protocols section “TLS 1.1” text color will be changed to Orange by end of November 2018.

Εικόνα 1.5. Πληροφορίες για την ευπάθεια της ιστοσελίδας στο πεδίο «Protocol Support»

Το άρθρο αναφέρει για ιστοσελίδες που υποστηρίζουν παλαιότερες εκδόσεις του TLS που είχαν κάποιες ευπάθειες, οι οποίες έχουν διορθωθεί στην νεότερη έκδοση του που είναι η TLS 1.3. Εξού και ο βαθμός «B» από το εργαλείο έρευνας. Τέλος, είδαμε και την ανάλυση των εκδόσεων του πρωτοκόλλου και των κρυπτογραφικών σουιτών που υποστηρίζει η συγκεκριμένη ιστοσελίδα.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

			Protocols	
TLS 1.3		No		
TLS 1.2		Yes		
TLS 1.1		Yes		
TLS 1.0		Yes		
SSL 3		No		
SSL 2		No		
			Cipher Suites	
# TLS 1.2 (suites in server-preferred order)				
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)	ECDH secp256r1 (eq. 3072 bits RSA) FS	128		
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030)	ECDH secp256r1 (eq. 3072 bits RSA) FS	256		
TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 (0x9e)	DH 2048 bits FS	128		
TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 (0x9f)	DH 2048 bits FS	256		
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027)	ECDH secp256r1 (eq. 3072 bits RSA) FS	128	WEAK	
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)	ECDH secp256r1 (eq. 3072 bits RSA) FS	128	WEAK	
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (0xc028)	ECDH secp256r1 (eq. 3072 bits RSA) FS	256	WEAK	
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)	ECDH secp256r1 (eq. 3072 bits RSA) FS	256	WEAK	
TLS_DHE_RSA_WITH_AES_128_CBC_SHA256 (0x67)	DH 2048 bits FS	128	WEAK	
TLS_DHE_RSA_WITH_AES_256_CBC_SHA256 (0x6b)	DH 2048 bits FS	256	WEAK	
TLS_RSA_WITH_AES_128_GCM_SHA256 (0x9c)		128	WEAK	
TLS_RSA_WITH_AES_256_GCM_SHA384 (0x9d)		256	WEAK	
TLS_RSA_WITH_AES_128_CBC_SHA256 (0x3c)		128	WEAK	
TLS_RSA_WITH_AES_256_CBC_SHA256 (0x3d)		256	WEAK	
TLS_RSA_WITH_AES_128_CBC_SHA (0x2f)		128	WEAK	
TLS_RSA_WITH_AES_256_CBC_SHA (0x35)		256	WEAK	
TLS_RSA_WITH_3DES_EDE_CBC_SHA (0xa)		112	WEAK	
# TLS 1.1 (suites in server-preferred order)				
# TLS 1.0 (suites in server-preferred order)				

Εικόνα 1.6. Ανάλυση των εκδόσεων του πρωτοκόλλου και των κρυπτογραφικών σουϊτών

Έρευνα από το εγκατεστημένο εργαλείο

Αρχικά, ανοίξαμε το τερματικό της μηχανής και μεταφερθήκαμε στον κατάλογο που βρίσκεται το python2 script με την εντολή

```
cd a2sv
```

Από την Εικόνα 1.3, πήραμε την IP Address της ιστοσελίδας και την βάλαμε ως παράμετρο για να τρέξουμε την εντολή :

```
python2 a2sv.py -t 80.245.171.70
```

Στη συνέχεια, είδαμε τα αποτελέσματα της έρευνας.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

```
[A2SV REPORT]
[TARGET]: 80.245.171.70
[PORT]: 443
[SCAN TIME]: 2023-06-18 19:16:33.167040
[VULNERABILITY]
Vulnerability    CVE          CVSS v2 Base Score    State
=====
Anonymous Cipher CVE-2007-1858 AV:N/AC:H/Au:N/C:P/I:N/A:N Vulnerable!
CRIME(SPDY)      CVE-2012-4929 AV:N/AC:H/Au:N/C:P/I:N/A:N Vulnerable!
HeartBleed      CVE-2014-0160 AV:N/AC:L/Au:N/C:P/I:N/A:N Not Vulnerable.
CCS Injection   CVE-2014-0224 AV:N/AC:M/Au:N/C:P/I:P/A:P Not Vulnerable.
SSLv3 POODLE    CVE-2014-3566 AV:N/AC:M/Au:N/C:P/I:N/A:N Not Vulnerable.
OpenSSL FREAK   CVE-2015-0204 AV:N/AC:M/Au:N/C:N/I:P/A:N Not Vulnerable.
OpenSSL LOGJAM  CVE-2015-4000 AV:N/AC:M/Au:N/C:N/I:P/A:N Not Vulnerable.
SSLv2 DROWN     CVE-2016-0800 AV:N/AC:M/Au:N/C:P/I:N/A:N Not Vulnerable.
[FIN] Scan Finish!
```

Εικόνα 1.7. Τα αποτελέσματα της συνοπτικής έρευνας του εγκατεστημένου εργαλείου

Η έρευνα έδειξε ότι η ιστοσελίδα έχει ευπάθεια σε επιθέσεις τύπου Anonymous Cipher και CRIME και αυτό οφείλεται στο ότι υποστηρίζει παλιές εκδόσεις του TLS. Τέλος, είδαμε και τους αναλυτικούς ελέγχους της έρευνας για κάθε τύπου επίθεση που ελέγχει το εργαλείο (CRIME, DROWN, FREAK, HeartBleed, LOGJAM).

```
GREEN
[INF] Check the SSL..
[RES] This target supports SSL..
[INF] Scan Anonymous Cipher..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection
- [LOG] Analysis SSL Information
- [LOG] 'Connection fail'
[INF] Scan CRIME(SPDY)..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection
- [LOG] Analysis SSL Information
- [LOG] 'Includes SPDY version <4'
[INF] Scan CCS Injection..
- [LOG] TLSv1.2 80.245.171.70:443 rejected early CCS
- [LOG] TLSv1.1 80.245.171.70:443 rejected early CCS
- [LOG] TLSv1 80.245.171.70:443 rejected early CCS
- [LOG] [SSLv3] 80.245.171.70:443 Invalid handshake.
[INF] Scan HeartBleed..
- [LOG] Sending Client Hello...
- [LOG] Waiting for Server Hello...
- [LOG] Sending heartbeat request..
[INF] Scan SSLv3 POODLE..
- [LOG] Invalid SSLv3 handshake.
[INF] Scan OpenSSL FREAK..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection / Gathering Information
- [LOG] Ending Get Information
- [LOG] 'Cipher is EXP' not in Response
[INF] Scan OpenSSL LOGJAM..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection / Gathering Information
- [LOG] Ending Get Information
- [LOG] 'Cipher is DEH' not in Response
[INF] Scan SSLv2 DROWN..
- [LOG] Not connected SSLv2
[RES] Finish scan all vulnerability..
```

Εικόνα 1.8. Τα αποτελέσματα της αναλυτικής έρευνας του εγκατεστημένου εργαλείου

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Συμφωνίες και διαφωνίες των εργαλείων

Το web εργαλείο πραγματοποιεί εκτενέστερους ελέγχους από το εγκατεστημένο, αλλά παρόλα αυτά συμφωνούν και τα δύο εργαλεία ότι η ιστοσελίδα έχει ευπάθειες λόγω το ότι υποστηρίζει παλαιότερες εκδόσεις του TLS.

2. TLS Scanning σε ειδησεογραφικά sites

Ιστοσελίδα

Για την ανάγκη της δραστηριότητας χρησιμοποιήθηκε το site <https://www.newsbomb.gr/> ειδησεογραφικού site, προκειμένου να ελεγχθεί ως προς την αξιοπιστία του στο πρωτόκολλο TLS.

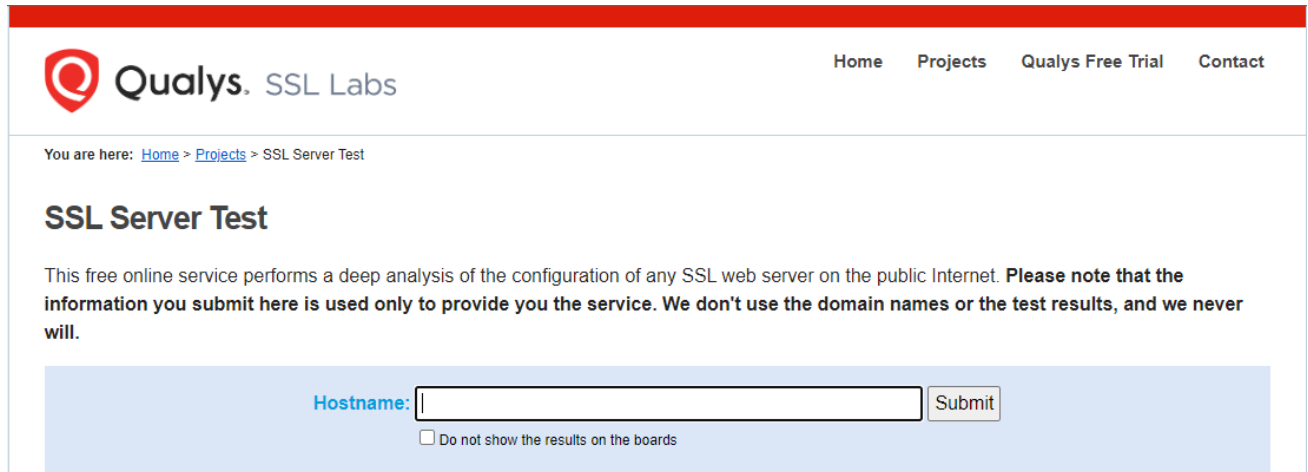


Εικόνα 2.1. Η ιστοσελίδα ειδησεογραφικού site, newsbomb

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Έρευνα από το web εργαλείο

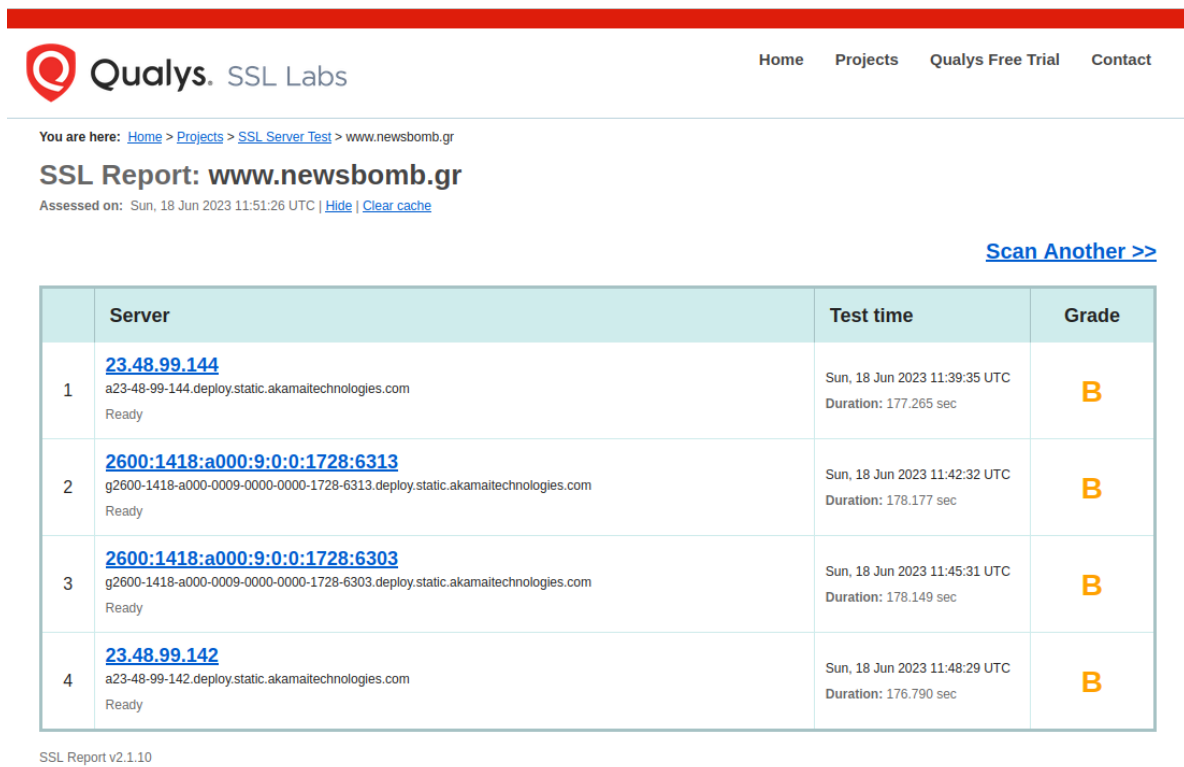
Αρχικά, χρησιμοποιήσαμε το web εργαλείο <https://www.ssllabs.com/ssltest/>.



The screenshot shows the Qualys SSL Labs website. The header includes the Qualys logo and navigation links: Home, Projects, Qualys Free Trial, and Contact. Below the header, a breadcrumb trail reads: You are here: Home > Projects > SSL Server Test. The main heading is "SSL Server Test". A paragraph explains the service: "This free online service performs a deep analysis of the configuration of any SSL web server on the public Internet. Please note that the information you submit here is used only to provide you the service. We don't use the domain names or the test results, and we never will." Below this is a form with a "Hostname:" label, a text input field, and a "Submit" button. A checkbox labeled "Do not show the results on the boards" is also present.

Εικόνα 2.2. Το web εργαλείο SSL Labs

Βάλαμε το URL της ιστοσελίδας στο πεδίο Hostname που παρέχει το εργαλείο και είδαμε τα αποτελέσματα της έρευνας και τα ψηφιακά πιστοποιητικά της ιστοσελίδας στο <https://www.ssllabs.com/ssltest/analyze.html?d=www.newsbomb.gr>.



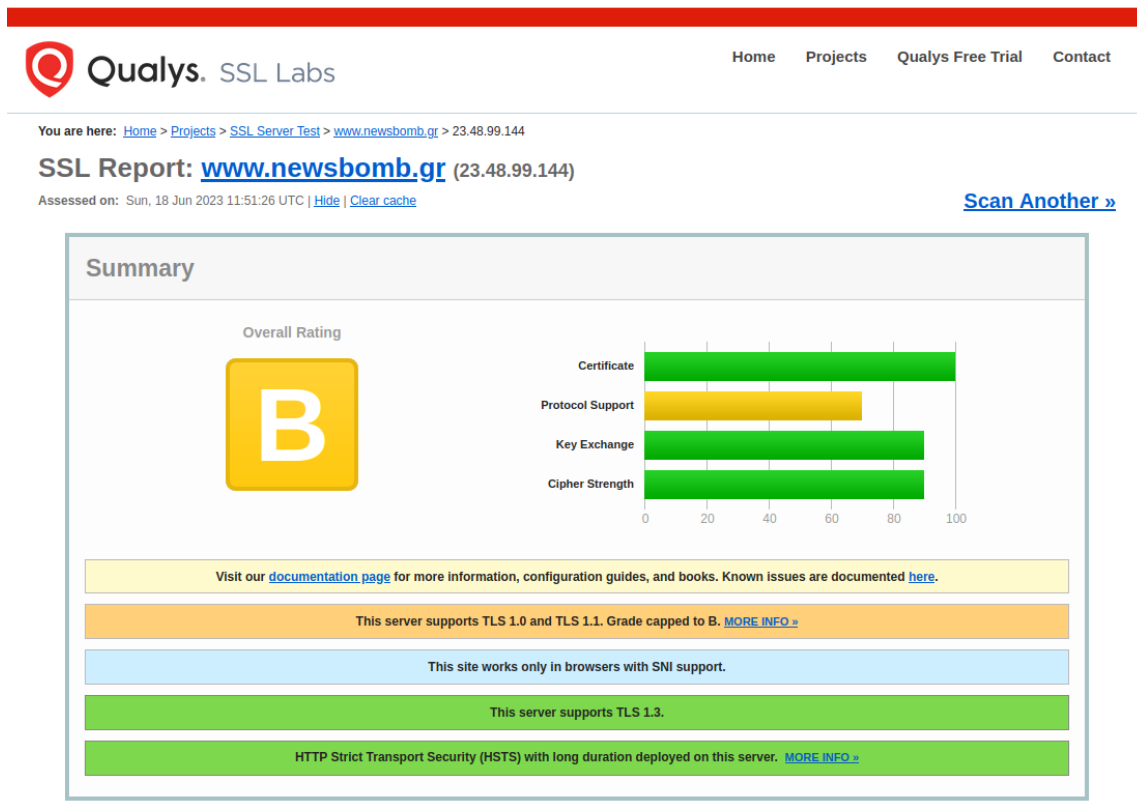
The screenshot shows the SSL Report for www.newsbomb.gr. The header includes the Qualys logo and navigation links: Home, Projects, Qualys Free Trial, and Contact. Below the header, a breadcrumb trail reads: You are here: Home > Projects > SSL Server Test > www.newsbomb.gr. The main heading is "SSL Report: www.newsbomb.gr". Below this, it says "Assessed on: Sun, 18 Jun 2023 11:51:26 UTC | Hide | Clear cache". A link "Scan Another >>" is also present. The main content is a table with 4 rows and 4 columns: Server, Test time, and Grade. The table shows the results of the SSL test for the domain www.newsbomb.gr.

	Server	Test time	Grade
1	23.48.99.144 a23-48-99-144.deploy.static.akamaitechnologies.com Ready	Sun, 18 Jun 2023 11:39:35 UTC Duration: 177.265 sec	B
2	2600:1418:a000:9:0:0:1728:6313 g2600-1418-a000-0009-0000-0000-1728-6313.deploy.static.akamaitechnologies.com Ready	Sun, 18 Jun 2023 11:42:32 UTC Duration: 178.177 sec	B
3	2600:1418:a000:9:0:0:1728:6303 g2600-1418-a000-0009-0000-0000-1728-6303.deploy.static.akamaitechnologies.com Ready	Sun, 18 Jun 2023 11:45:31 UTC Duration: 178.149 sec	B
4	23.48.99.142 a23-48-99-142.deploy.static.akamaitechnologies.com Ready	Sun, 18 Jun 2023 11:48:29 UTC Duration: 176.790 sec	B

SSL Report v2.1.10

Εικόνα 2.3. Τα αποτελέσματα της έρευνας του web εργαλείου

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



Εικόνα 2.4. Τα αποτελέσματα της έρευνας του web εργαλείου για την 1^η IP Address

Certificate #1: EC 256 bits (SHA256withRSA)	
Subject	www.clickhouse.gr Fingerprint SHA256: 4d6b0a7b127dcf81151b469596673ea819c39c3e5e1c49151f9862567b8196 Pin SHA256: 9t66xSMGZ4w+LguQjXVd6d6WWTaQt+WBEd6eJZF4s=
Common names	www.clickhouse.gr
Alternative names	www.clickhouse.gr amp.astrology.gr amp.cnn.gr amp.dokari.gr amp.gossip-tv.gr amp.mothersblog.gr amp.newsbomb.gr amp.onmed.gr amp.onsports.gr amp.queen.gr amp.ratpack.gr astro.bbend.net cdn.cnngrreece.gr cdn1.bbend.net cnn.bbend.net dokari.bbend.net gos.bbend.net i.cnn.bbend.net i.dokari.bbend.net imggossip.bbend.net imgmothers.bbend.net imgonmed.bbend.net imgqueen.bbend.net imgleen.bbend.net mothers.bbend.net nb.bbend.net onmed.bbend.net onsports.bbend.net plus.bbend.net plus.queen.gr queen.bbend.net ratpack.bbend.net staticgossip.bbend.net staticmothers.bbend.net staticqueen.bbend.net staticteen.bbend.net teen.bbend.net teen.queen.gr widgets.bbend.com www.astrology.gr www.cnn.gr www.dokari.gr www.gossip-tv.gr www.mothersblog.gr www.newsbomb.gr www.onmed.gr www.onsports.gr www.queen.gr www.ratpack.gr
Serial Number	09c38022104f2685dd7f7bb21e18e2d3
Valid from	Tue, 07 Feb 2023 00:00:00 UTC
Valid until	Tue, 15 Aug 2023 23:59:59 UTC (expires in 1 month and 28 days)
Key	EC 256 bits
Weak key (Debian)	No
Issuer	DigiCert TLS RSA SHA256 2020 CA1 AIA: http://cacerts.digicert.com/DigiCertTLRSASHA2562020CA1-1.crt
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	CRL, OCSP CRL: http://crl3.digicert.com/DigiCertTLRSASHA2562020CA1-4.crl OCSP: http://ocsp.digicert.com
Revocation status	Good (not revoked)
DNS CAA	No (more info)
Trusted	Yes Mozilla Apple Android Java Windows

Εικόνα 2.5. Το 1^ο ψηφιακό πιστοποιητικό του server

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Certificate #2: RSA 2048 bits (SHA256withRSA) No SNI	
Server Key and Certificate #1	
Subject	a248.e.akamai.net Fingerprint SHA256: e80324a8c7f07d743fea0ed2b0a2fb16821a671d737df9ab4473f7da667a0354 Pin SHA256: VOVK64yz1XMrU1XA9nqBHLJCGGGEFFQJ2YHshgQmfsC=
Common names	a248.e.akamai.net
Alternative names	a248.e.akamai.net *.akamaized.net *.akamaized-staging.net *.akamaihd.net *.akamaihd-staging.net MISMATCH
Serial Number	0aa20442bdf514af732e252f8e924383
Valid from	Tue, 16 May 2023 00:00:00 UTC
Valid until	Wed, 15 May 2024 23:59:59 UTC (expires in 10 months and 27 days)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	DigiCert TLS RSA SHA256 2020 CA1 AIA: http://cacerts.digicert.com/DigiCertTLRSASHA2562020CA1-1.crt
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	CRL, OCSP CRL: http://crl3.digicert.com/DigiCertTLRSASHA2562020CA1-4.crl OCSP: http://ocsp.digicert.com
Revocation status	Good (not revoked)
Trusted	No NOT TRUSTED Mozilla Apple Android Java Windows

Εικόνα 2.6. Το 2^ο ψηφιακό πιστοποιητικό του server

Certificate #3: RSA 2048 bits (SHA256withRSA)	
Server Key and Certificate #1	
Subject	www.clickhouse.gr Fingerprint SHA256: 0163d48712b0d36b292d3ac9438128eed1c3545d690b037ae8e4fa5eaa87e6 Pin SHA256: frzNp7GM8CXe2G4ae46ZKkt8ajyIOMuu+HZF8ebgsNE=
Common names	www.clickhouse.gr
Alternative names	www.clickhouse.gr www.ratpack.gr www.queen.gr www.onsports.gr www.onmed.gr www.newsbomb.gr www.mothersblog.gr www.gossip-tv.gr www.dokari.gr www.cnn.gr www.astrology.gr widgets.bbend.com teen.queen.gr teen.bbend.net staticteen.bbend.net staticqueen.bbend.net staticmothers.bbend.net staticgossip.bbend.net ratpack.bbend.net queen.bbend.net plus.queen.gr plus.bbend.net onsports.bbend.net onmed.bbend.net nb.bbend.net mothers.bbend.net imgteen.bbend.net imgqueen.bbend.net imgonmed.bbend.net imgmothers.bbend.net imggossip.bbend.net i.dokari.bbend.net i.cnn.bbend.net gos.bbend.net dokari.bbend.net cnn.bbend.net cdn1.bbend.net cdn.cngreece.gr astro.bbend.net amp.ratpack.gr amp.queen.gr amp.onsports.gr amp.onmed.gr amp.newsbomb.gr amp.mothersblog.gr amp.gossip-tv.gr amp.dokari.gr amp.cnn.gr amp.astrology.gr
Serial Number	01fb3dd5950f4115cbe5b5de6ef92d4e
Valid from	Mon, 06 Feb 2023 00:00:00 UTC
Valid until	Tue, 15 Aug 2023 23:59:59 UTC (expires in 1 month and 28 days)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	DigiCert TLS RSA SHA256 2020 CA1 AIA: http://cacerts.digicert.com/DigiCertTLRSASHA2562020CA1-1.crt
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	CRL, OCSP CRL: http://crl3.digicert.com/DigiCertTLRSASHA2562020CA1-4.crl OCSP: http://ocsp.digicert.com
Revocation status	Good (not revoked)
DNS CAA	No (more info)
Trusted	Yes Mozilla Apple Android Java Windows

Εικόνα 2.7. Το 3^ο ψηφιακό πιστοποιητικό του server

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Η έρευνα έδειξε ότι ο βαθμός αξιοπιστίας της ιστοσελίδας ως προς το πρωτόκολλο TLS είναι «B» σε κάθε IP Address που διαθέτει (διαλέξαμε την 1^η μόνο για την έρευνα), που σημαίνει ότι παρουσιάζει ευπάθεια και συγκεκριμένα στο «Protocol Support» που είναι με κίτρινο χρώμα (σε αντίθεση με τα άλλα που είναι πράσινα στο ραβδόγραμμα δίπλα από τον βαθμό). Αναζητήσαμε περισσότερες πληροφορίες στο πεδίο που λέει :

“The server supports TLS 1.0 and TLS 1.1. Grade capped to B. MORE INFO”

και συγκεκριμένα στο άρθρο https://blog.qualys.com/product-tech/2017/03/13/caa-mandated-by-cabrowser-forum?_ga=2.204699411.2017122474.1687046115-1545449628.1687046115

SSL Labs Grade Change for TLS 1.0 and TLS 1.1 Protocols



Yash Sannegowda

November 19, 2018 - 4 min read

👍 49

Last updated on: December 16, 2022



Qualys. SSL Labs

Update 1/31/2020: The grade change is now live on www.ssllabs.com. Servers that support TLS 1.0 or TLS 1.1 are capped to B grade.

Update 1/16/2020: The grade change is now live on the development server at dev.ssllabs.com. Servers that support TLS 1.0 or TLS 1.1 are capped to B grade on the development server. Deployment to production SSL Labs servers is planned for the very end of January.

Update 10/11/19: The TLS 1.0/1.1 warning changes are now live on www.ssllabs.com. The grade change for supporting TLS 1.0/1.1 is changed from March 2020 to January 2020 as shown below in the “SSL Labs Grade Change” section below and as reflected in the summary messages in SSL Labs results.

Update 11/30/18: Now live on ssllabs.com: In Configuration->Protocols section “TLS 1.1” text color will be changed to Orange by end of November 2018.

Εικόνα 2.8. Πληροφορίες για την ευπάθεια της ιστοσελίδας στο πεδίο «Protocol Support»

Το άρθρο αναφέρει για ιστοσελίδες που υποστηρίζουν παλαιότερες εκδόσεις του TLS που είχαν κάποιες ευπάθειες, οι οποίες έχουν διορθωθεί στην νεότερη έκδοση του που είναι η TLS 1.3. Εξού και ο βαθμός «B» από το εργαλείο έρευνας. Τέλος, είδαμε και την ανάλυση των εκδόσεων του πρωτοκόλλου και των κρυπτογραφικών σουιτών που υποστηρίζει η συγκεκριμένη ιστοσελίδα.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

		Protocols	
TLS 1.3			Yes
TLS 1.2			Yes*
TLS 1.1			Yes
TLS 1.0			Yes*
SSL 3			No
SSL 2			No
(*) Experimental: Server negotiated using No-SNI			
		Cipher Suites	
# TLS 1.3 (suites in server-preferred order)			
TLS_AES_256_GCM_SHA384 (0x1302)	ECDH x25519 (eq. 3072 bits RSA)	FS	256
TLS_CHACHA20_POLY1305_SHA256 (0x1303)	ECDH x25519 (eq. 3072 bits RSA)	FS	256 ^P
TLS_AES_128_GCM_SHA256 (0x1301)	ECDH x25519 (eq. 3072 bits RSA)	FS	128
TLS_AES_128_CCM_8_SHA256 (0x1305)	ECDH x25519 (eq. 3072 bits RSA)	FS	128
TLS_AES_128_CCM_SHA256 (0x1304)	ECDH x25519 (eq. 3072 bits RSA)	FS	128
# TLS 1.2 (suites in server-preferred order)			
TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384 (0xc02c)	ECDH secp256r1 (eq. 3072 bits RSA)	FS	256
TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256 (0xc02b)	ECDH secp256r1 (eq. 3072 bits RSA)	FS	128
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030)	ECDH secp256r1 (eq. 3072 bits RSA)	FS	256
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)	ECDH secp256r1 (eq. 3072 bits RSA)	FS	128
TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256 (0xcca9)	ECDH secp256r1 (eq. 3072 bits RSA)	FS	256 ^P
TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (0xcca8)	ECDH secp256r1 (eq. 3072 bits RSA)	FS	256 ^P
TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA384 (0xc024)	ECDH secp256r1 (eq. 3072 bits RSA)	FS	WEAK 256
TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA256 (0xc023)	ECDH secp256r1 (eq. 3072 bits RSA)	FS	WEAK 128
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (0xc028)	ECDH secp256r1 (eq. 3072 bits RSA)	FS	WEAK 256
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027)	ECDH secp256r1 (eq. 3072 bits RSA)	FS	WEAK 128
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)	ECDH secp256r1 (eq. 3072 bits RSA)	FS	WEAK 256
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)	ECDH secp256r1 (eq. 3072 bits RSA)	FS	WEAK 128

Εικόνα 2.9. Ανάλυση των εκδόσεων του πρωτοκόλλου και των κρυπτογραφικών σουιτών

Έρευνα από το εγκατεστημένο εργαλείο

Αρχικά, ανοίξαμε το τερματικό της μηχανής και μεταφερθήκαμε στον κατάλογο που βρίσκεται το python2 script με την εντολή

```
cd a2sv
```

Από την Εικόνα 2.4, πήραμε την IP Address της ιστοσελίδας και την βάλαμε ως παράμετρο για να τρέξουμε την εντολή :

```
python2 a2sv.py -t 23.48.99.144
```

Στη συνέχεια, είδαμε τα αποτελέσματα της έρευνας.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

[A2SV REPORT]			
[TARGET]: 23.48.99.144			
[PORT]: 443			
[SCAN TIME]: 2023-06-18 19:19:05.195292			
[VULNERABILITY]			
Vulnerability	CVE	CVSS v2 Base Score	State
Anonymous Cipher	CVE-2007-1858	AV:N/AC:H/Au:N/C:P/I:N/A:N	Not Vulnerable.
CRIME(SPDY)	CVE-2012-4929	AV:N/AC:H/Au:N/C:P/I:N/A:N	Vulnerable!
HeartBleed	CVE-2014-0160	AV:N/AC:L/Au:N/C:P/I:N/A:N	Not Vulnerable.
CCS Injection	CVE-2014-0224	AV:N/AC:M/Au:N/C:P/I:P/A:P	Not Vulnerable.
SSLv3 POODLE	CVE-2014-3566	AV:N/AC:M/Au:N/C:P/I:N/A:N	Not Vulnerable.
OpenSSL FREAK	CVE-2015-0204	AV:N/AC:M/Au:N/C:N/I:P/A:N	Not Vulnerable.
OpenSSL LOGJAM	CVE-2015-4000	AV:N/AC:M/Au:N/C:N/I:P/A:N	Not Vulnerable.
SSLv2 DROWN	CVE-2016-0800	AV:N/AC:M/Au:N/C:P/I:N/A:N	Exception
[FIN] Scan Finish!			

Εικόνα 2.10. Τα αποτελέσματα της συνοπτικής έρευνας του εγκατεστημένου εργαλείου

Η έρευνα έδειξε ότι η ιστοσελίδα έχει ευπάθεια σε επιθέσεις τύπου CRIME και αυτό οφείλεται στο ότι υποστηρίζει παλιές εκδόσεις του TLS. Τέλος, είδαμε και τους αναλυτικούς έλεγχους της έρευνας για κάθε τύπου επίθεση που ελέγχει το εργαλείο (CRIME, DROWN, FREAK, HeartBleed, LOGJAM).

```
GREEN
[INF] Check the SSL..
[RES] This target supports SSL..
[INF] Scan Anonymous Cipher..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection
- [LOG] Analysis SSL Information
- [LOG] 'Connection success'
[INF] Scan CRIME(SPDY)..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection
- [LOG] Analysis SSL Information
- [LOG] 'Includes SPDY version <4'
[INF] Scan CCS Injection..
- [LOG] TLSv1.2 23.48.99.144:443 rejected early CCS
- [LOG] TLSv1.1 23.48.99.144:443 rejected early CCS
- [LOG] TLSv1 23.48.99.144:443 rejected early CCS
- [LOG] [SSLv3] 23.48.99.144:443 Invalid handshake.
[INF] Scan HeartBleed..
- [LOG] Sending Client Hello...
- [LOG] Waiting for Server Hello...
- [LOG] Sending heartbeat request..
[INF] Scan SSLv3 POODLE..
- [LOG] Invalid SSLv3 handshake.
[INF] Scan OpenSSL FREAK..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection / Gathering Information
- [LOG] Ending Get Information
- [LOG] 'Cipher is EXP' not in Response
[INF] Scan OpenSSL LOGJAM..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection / Gathering Information
- [LOG] Ending Get Information
- [LOG] 'Cipher is DEH' not in Response
[INF] Scan SSLv2 DROWN..
invalid literal for int() with base 16: ''
[RES] Finish scan all vulnerability..
```

Εικόνα 2.9. Τα αποτελέσματα της αναλυτικής έρευνας του εγκατεστημένου εργαλείου

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Συμφωνίες και διαφωνίες των εργαλείων

Το web εργαλείο πραγματοποιεί εκτενέστερους ελέγχους από το εγκατεστημένο, αλλά παρόλα αυτά συμφωνούν και τα δύο εργαλεία ότι η ιστοσελίδα έχει ευπάθειες λόγω το ότι υποστηρίζει παλαιότερες εκδόσεις του TLS.

3. TLS Scanning σε sites Πανεπιστημίων

Ιστοσελίδα

Για την ανάγκη της δραστηριότητας χρησιμοποιήθηκε το πανεπιστημιακό site <https://www.hua.gr/index.php/el/>, προκειμένου να ελεγχθεί ως προς την αξιοπιστία του στο πρωτόκολλο TLS.

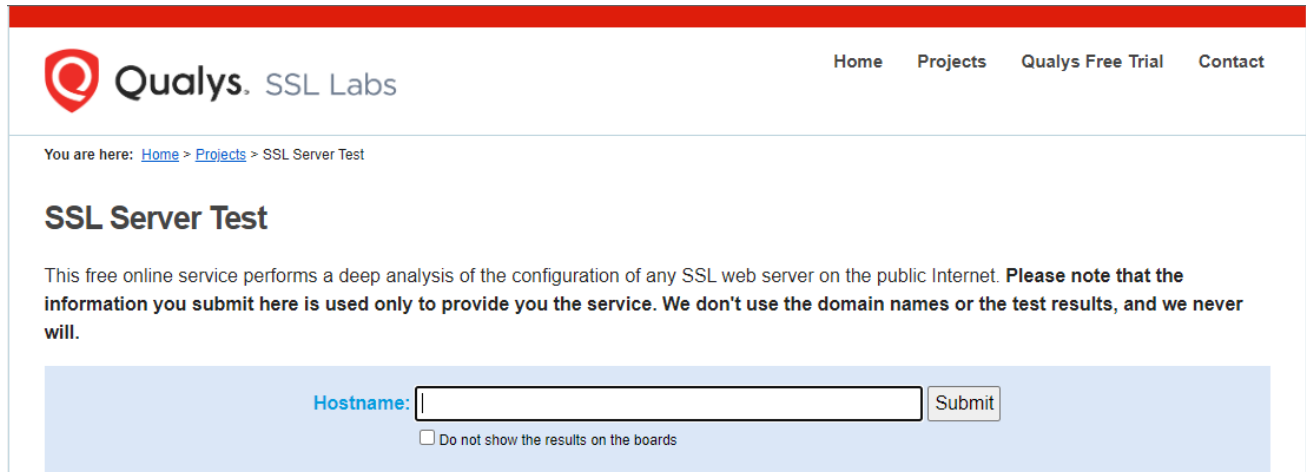


Εικόνα 3.1. Το πανεπιστημιακό site του Χαροκοπείου

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Έρευνα από το web εργαλείο

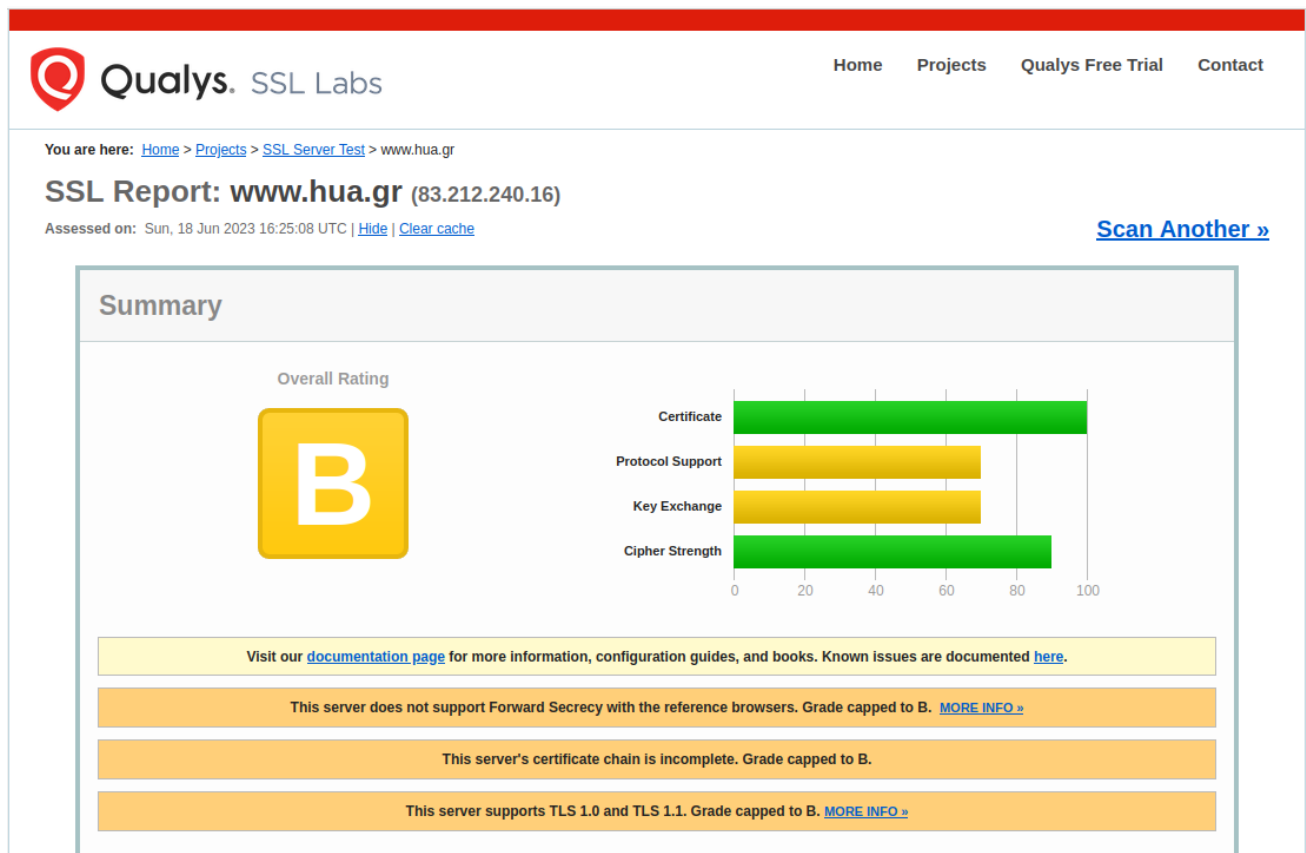
Αρχικά, χρησιμοποιήσαμε το web εργαλείο <https://www.ssllabs.com/ssltest/>.



The screenshot shows the Qualys SSL Labs website. The header includes the Qualys logo and navigation links: Home, Projects, Qualys Free Trial, and Contact. Below the header, the breadcrumb trail reads: You are here: Home > Projects > SSL Server Test. The main heading is "SSL Server Test". A paragraph explains the service: "This free online service performs a deep analysis of the configuration of any SSL web server on the public Internet. Please note that the information you submit here is used only to provide you the service. We don't use the domain names or the test results, and we never will." Below this is a form with a "Hostname:" label, a text input field, and a "Submit" button. A checkbox labeled "Do not show the results on the boards" is also present.

Εικόνα 3.2. Το web εργαλείο SSL Labs

Βάλαμε το URL της ιστοσελίδας στο πεδίο Hostname που παρέχει το εργαλείο και είδαμε τα αποτελέσματα της έρευνας και τα ψηφιακά πιστοποιητικά της ιστοσελίδας στο <https://www.ssllabs.com/ssltest/analyze.html?d=www.hua.gr>.



Εικόνα 3.3. Τα αποτελέσματα της έρευνας του web εργαλείου

Certificate #1: RSA 2048 bits (SHA384withRSA)	
 Server Key and Certificate #1 	
Subject	*.hua.gr Fingerprint SHA256: bbf619f1e9fd7564ca5a18715c9a52a51059ed6b5a6f6d58aeb2606a1e28d022 Pin SHA256: b0c1cSqJsn0NRPP98vvgQfp+RU8hOMo0n3YJLkwp+9l=
Common names	*.hua.gr
Alternative names	*.hua.gr hua.gr
Serial Number	4d8178c8ce7929ba601f2ccee62e0d8a
Valid from	Wed, 30 Nov 2022 00:00:00 UTC
Valid until	Thu, 30 Nov 2023 23:59:59 UTC (expires in 5 months and 12 days)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	GEANT OV RSA CA 4 AIA: http://GEANT.crl.sectigo.com/GEANTOVRSA4.crl
Signature algorithm	SHA384withRSA
Extended Validation	No
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	CRL, OCSP CRL: http://GEANT.crl.sectigo.com/GEANTOVRSA4.crl OCSP: http://GEANT.ocsp.sectigo.com
Revocation status	Good (not revoked)
DNS CAA	No (more info)
Trusted	Yes Mozilla Apple Android Java Windows

Εικόνα 3.4. Το ψηφιακό πιστοποιητικό του server

Η έρευνα έδειξε ότι ο βαθμός αξιοπιστίας της ιστοσελίδας ως προς το πρωτόκολλο TLS είναι «B» που σημαίνει ότι παρουσιάζει ευπάθεια και συγκεκριμένα στο «Protocol Support» και στο «Key Exchange» που είναι με κίτρινο χρώμα (σε αντίθεση με τα άλλα που είναι πράσινα στο ραβδόγραμμα δίπλα από τον βαθμό). Αναζητήσαμε περισσότερες πληροφορίες στα πεδία που λένε :

“The server does not support Forward Secrecy with the reference browsers. Grade capped to B. MORE INFO”

και συγκεκριμένα στο άρθρο https://blog.qualys.com/product-tech/2018/02/02/forward-secrecy-authenticated-encryption-and-robot-grading-update?_ga=2.218329754.2017122474.1687046115-1545449628.1687046115

“The server supports TLS 1.0 and TLS 1.1. Grade capped to B. MORE INFO”

και συγκεκριμένα στο άρθρο https://blog.qualys.com/product-tech/2017/03/13/caa-mandated-by-cabrowser-forum?_ga=2.204699411.2017122474.1687046115-1545449628.1687046115

SSL Labs Grade Change for TLS 1.0 and TLS 1.1 Protocols



Yash Sannegowda

November 19, 2018 - 4 min read

👍 49

Last updated on: December 16, 2022



Update 1/31/2020: The grade change is now live on www.ssllabs.com. Servers that support TLS 1.0 or TLS 1.1 are capped to B grade.

Update 1/16/2020: The grade change is now live on the development server at dev.ssllabs.com. Servers that support TLS 1.0 or TLS 1.1 are capped to B grade on the development server. Deployment to production SSL Labs servers is planned for the very end of January.

Update 10/11/19: The TLS 1.0/1.1 warning changes are now live on www.ssllabs.com. The grade change for supporting TLS 1.0/1.1 is changed from March 2020 to January 2020 as shown below in the “SSL Labs Grade Change” section below and as reflected in the summary messages in SSL Labs results.

Update 11/30/18: Now live on ssllabs.com: In Configuration->Protocols section “TLS 1.1” text color will be changed to Orange by end of November 2018.

Εικόνα 3.5. Πληροφορίες για την ευπάθεια της ιστοσελίδας στο πεδίο «Protocol Support»

Το άρθρο αναφέρει για ιστοσελίδες που υποστηρίζουν παλαιότερες εκδόσεις του TLS που είχαν κάποιες ευπάθειες, οι οποίες έχουν διορθωθεί στην νεότερη έκδοση του που είναι η TLS 1.3. Εξού και ο βαθμός «B» από το εργαλείο έρευνας.

Penalty for not using forward secrecy (B)

Forward secrecy (FS) also known as perfect forward secrecy (PFS), is a property of secure communication protocols in which compromises of long-term keys does not compromise past session keys. Forward secrecy protects past sessions against future compromises of private key. The very popular RSA key exchange doesn't provide forward secrecy. You need to support and prefer ECDHE suites in order to enable forward secrecy with modern web browsers.

SSL Labs will start penalizing servers that don't support forward secrecy; Grade will be capped to B. We will not penalize sites that use suites without forward secrecy provided they are never negotiated with clients that can do better.

Penalty for not using AEAD suites (B)

Your site should use [secure cipher suites](#). AEAD is the only encryption approach without any known weaknesses. The alternative, CBC encryption, is susceptible to timing attacks (as implemented in TLS). AEAD suites provide strong authentication, key exchange, forward secrecy, and encryption of at least 128 bits. TLS 1.3 supports only AEAD suites. SSL Labs doesn't currently reward the use of AEAD suites. In this grading criteria update we will start requiring AEAD suites for A.

Grade will be capped to B, if AEAD suites are not supported. As with forward secrecy, we will not penalize sites if they continue to use non-AEAD suites provided AEAD suites are negotiated with clients that support them.

We have talked about these changes in [Announcing SSL Labs Grading Changes for 2017](#).

Penalty for ROBOT vulnerability (F)

Return Of Bleichenbacher Oracle Threat, is an attack model based on Daniel Bleichenbacher chosen-ciphertext attack. Bleichenbacher discovered an adaptive-chosen ciphertext attack against protocols using RSA, he demonstrated the ability to perform RSA private-key operations. Researchers have been able to exploit the same vulnerability with small variations to the Bleichenbacher attack.

SSL Labs will start giving "F" grade to the servers affected by ROBOT vulnerability from ~~February 28,~~ 2018 March 1, 2018. Note: All changes described in this blog post go live on March 1.

SSL Labs has started giving a warning if the site doesn't support forward secrecy and/or AEAD suites; or if the site is vulnerable to ROBOT.

Penalty for using Symantec Certificates (T)

Starting March 1, 2018, SSL Labs will give "T" grade for Symantec certificates issued before June 2016.

See details in [Google and Mozilla are Deprecating Existing Symantec Certificates](#).

Εικόνα 3.6. Πληροφορίες για την ευπάθεια της ιστοσελίδας στο πεδίο «Key Exchange»

Το άρθρο αναφέρει για ιστοσελίδες που έχουν ανημέρωτο πιστοποιητικό, το οποίο χρησιμοποιεί παλιούς κρυπτογραφικούς αλγορίθμους κατά την χειραψία πελάτη-εξυπηρετητή. Οι αλγόριθμοι αυτοί υποστηρίζονται από παλαιές εκδόσεις του TLS που όπως είναι λογικό έχουν ευπάθειες. Το αποτέλεσμα είναι να τεθεί σε κίνδυνο σημαντική πληροφορία που αφορά την επικοινωνία των πρωτοκόλλων.

Τέλος, είδαμε και την ανάλυση των εκδόσεων του πρωτοκόλλου και των κρυπτογραφικών σουιτών που υποστηρίζει η συγκεκριμένη ιστοσελίδα.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

		Protocols	
TLS 1.3			No
TLS 1.2			Yes
TLS 1.1			Yes
TLS 1.0			Yes
SSL 3			No
SSL 2			No
		Cipher Suites	
# TLS 1.2 (server has no preference)			
TLS_RSA_WITH_AES_128_CBC_SHA (0x2f)	WEAK		128
TLS_DHE_RSA_WITH_AES_128_CBC_SHA (0x33)	DH 2048 bits FS WEAK		128
TLS_RSA_WITH_CAMELLIA_128_CBC_SHA (0x41)	WEAK		128
TLS_DHE_RSA_WITH_CAMELLIA_128_CBC_SHA (0x45)	DH 2048 bits FS WEAK		128
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK		128
TLS_RSA_WITH_AES_128_CBC_SHA256 (0x3c)	WEAK		128
TLS_DHE_RSA_WITH_AES_128_CBC_SHA256 (0x67)	DH 2048 bits FS WEAK		128
TLS_RSA_WITH_AES_128_GCM_SHA256 (0x9c)	WEAK		128
TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 (0x9e)	DH 2048 bits FS		128
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK		128
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f)	ECDH secp256r1 (eq. 3072 bits RSA) FS		128
TLS_RSA_WITH_AES_256_CBC_SHA (0x35)	WEAK		256
TLS_DHE_RSA_WITH_AES_256_CBC_SHA (0x39)	DH 2048 bits FS WEAK		256
TLS_RSA_WITH_CAMELLIA_256_CBC_SHA (0x84)	WEAK		256
TLS_DHE_RSA_WITH_CAMELLIA_256_CBC_SHA (0x88)	DH 2048 bits FS WEAK		256
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK		256
TLS_RSA_WITH_AES_256_CBC_SHA256 (0x3d)	WEAK		256
TLS_DHE_RSA_WITH_AES_256_CBC_SHA256 (0x6b)	DH 2048 bits FS WEAK		256
TLS_RSA_WITH_AES_256_GCM_SHA384 (0x9d)	WEAK		256
TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 (0x9f)	DH 2048 bits FS		256
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (0xc028)	ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK		256
TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030)	ECDH secp256r1 (eq. 3072 bits RSA) FS		256

Εικόνα 3.7. Ανάλυση των εκδόσεων του πρωτοκόλλου και των κρυπτογραφικών σουιτών

Έρευνα από το εγκατεστημένο εργαλείο

Αρχικά, ανοίξαμε το τερματικό της μηχανής και μεταφερθήκαμε στον κατάλογο που βρίσκεται το python2 script με την εντολή

```
cd a2sv
```

Από την Εικόνα 3.3, πήραμε την IP Address της ιστοσελίδας και την βάλαμε ως παράμετρο για να τρέξουμε την εντολή :

```
python2 a2sv.py -t 83.212.240.16
```

Στη συνέχεια, είδαμε τα αποτελέσματα της έρευνας.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

```
[A2SV REPORT]
[TARGET]: 83.212.240.16
[PORT]: 443
[SCAN TIME]: 2023-06-18 19:27:18.555361
[VULNERABILITY]
=====
Vulnerability    CVE             CVSS v2 Base Score    State
=====
Anonymous Cipher CVE-2007-1858    AV:N/AC:H/Au:N/C:P/I:N/A:N Vulnerable!
CRIME(SPDY)      CVE-2012-4929    AV:N/AC:H/Au:N/C:P/I:N/A:N Vulnerable!
HeartBleed       CVE-2014-0160    AV:N/AC:L/Au:N/C:P/I:N/A:N Not Vulnerable.
CCS Injection    CVE-2014-0224    AV:N/AC:M/Au:N/C:P/I:P/A:P Not Vulnerable.
SSLv3 POODLE     CVE-2014-3566    AV:N/AC:M/Au:N/C:P/I:N/A:N Not Vulnerable.
OpenSSL FREAK    CVE-2015-0204    AV:N/AC:M/Au:N/C:N/I:P/A:N Not Vulnerable.
OpenSSL LOGJAM   CVE-2015-4000    AV:N/AC:M/Au:N/C:N/I:P/A:N Not Vulnerable.
SSLv2 DROWN      CVE-2016-0800    AV:N/AC:M/Au:N/C:P/I:N/A:N Not Vulnerable.
=====
[FIN] Scan Finish!
```

Εικόνα 3.8. Τα αποτελέσματα της συνοπτικής έρευνας του εγκατεστημένου εργαλείου

Η έρευνα έδειξε ότι η ιστοσελίδα έχει ευπάθεια σε επιθέσεις τύπου CRIME και Anonymous Cipher και αυτό οφείλεται στο ότι υποστηρίζει παλιές εκδόσεις του TLS. Τέλος, είδαμε και τους αναλυτικούς έλεγχους της έρευνας για κάθε τύπου επίθεση που ελέγχει το εργαλείο (CRIME, DROWN, FREAK, HeartBleed, LOGJAM).

```
GREEN
[INF] Check the SSL..
[RES] This target supports SSL..
[INF] Scan Anonymous Cipher..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection
- [LOG] Analysis SSL Information
- [LOG] 'Connection fail'
[INF] Scan CRIME(SPDY)..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection
- [LOG] Analysis SSL Information
- [LOG] 'Includes SPDY version <4'
[INF] Scan CCS Injection..
- [LOG] TLSv1.2 83.212.240.16:443 rejected early CCS
- [LOG] TLSv1.1 83.212.240.16:443 rejected early CCS
- [LOG] TLSv1 83.212.240.16:443 rejected early CCS
- [LOG] [SSLv3] 83.212.240.16:443 Invalid handshake.
[INF] Scan HeartBleed..
- [LOG] Sending Client Hello...
- [LOG] Waiting for Server Hello...
- [LOG] Sending heartbeat request..
[INF] Scan SSLv3 POODLE..
- [LOG] Invalid SSLv3 handshake.
[INF] Scan OpenSSL FREAK..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection / Gathering Information
- [LOG] Ending Get Information
- [LOG] 'Cipher is EXP' not in Response
[INF] Scan OpenSSL LOGJAM..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection / Gathering Information
- [LOG] Ending Get Information
- [LOG] 'Cipher is DEH' not in Response
[INF] Scan SSLv2 DROWN..
- [LOG] Not connected SSLv2
[RES] Finish scan all vulnerability..
```

Εικόνα 3.9. Τα αποτελέσματα της αναλυτικής έρευνας του εγκατεστημένου εργαλείου

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Συμφωνίες και διαφωνίες των εργαλείων

Το web εργαλείο πραγματοποιεί εκτενέστερους ελέγχους από το εγκατεστημένο, αλλά παρόλα αυτά συμφωνούν και τα δύο εργαλεία ότι η ιστοσελίδα έχει ευπάθειες λόγω το ότι υποστηρίζει παλαιότερες εκδόσεις του TLS. Ωστόσο, το εγκατεστημένο εργαλείο δεν εντοπίζει την ευπάθεια όσον αφορά το πιστοποιητικό της ιστοσελίδας, καθώς ελέγχει ευπάθειες μόνο για συγκεκριμένους τύπους επιθέσεων.

4. TLS Scanning ύποπτης ιστοσελίδας

Ιστοσελίδα

Για την ανάγκη της δραστηριότητας χρησιμοποιήθηκε η ύποπτη ιστοσελίδα <https://www.blackboxresale.com/login.aspx>, προκειμένου να ελεγχθεί ως προς την αξιοπιστία του στο πρωτόκολλο TLS.

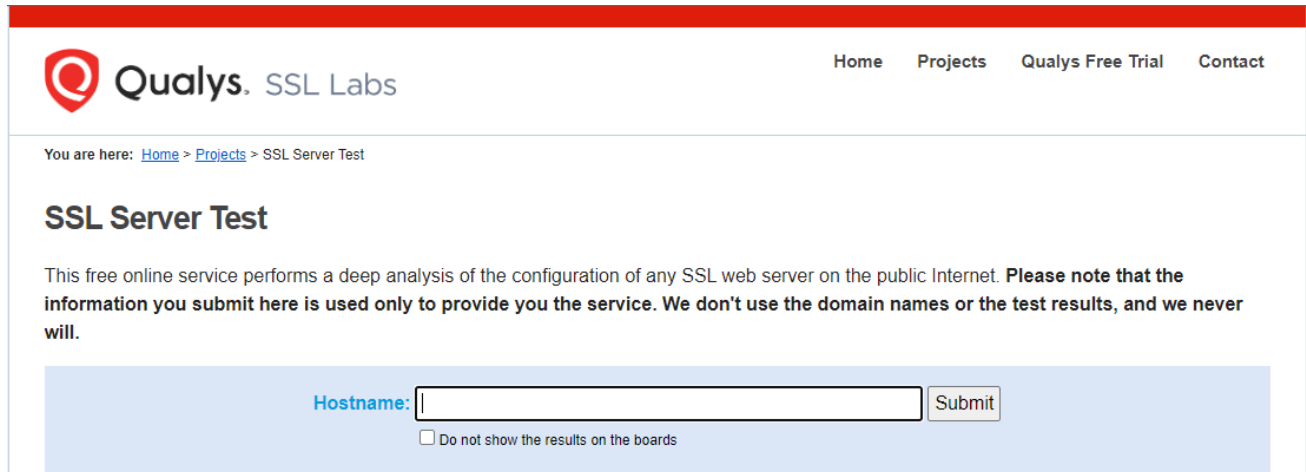
The screenshot displays the Black Box Resale Services website. At the top, there is a navigation bar with the company logo and contact information. Below this, a secondary navigation bar lists various sections: Solutions, Store/Catalog, Sell to Us, Support, and About. The main content area is divided into two sections: 'Current Users' and 'New Users'. The 'Current Users' section contains a login form with fields for Username and Password, a 'login' button, and a link to 'Forgot Your Password? Click here.' The 'New Users' section contains a registration form with fields for Username, Email, First Name, Last Name, Password, Confirm Password, Password Hint, and Password Answer, along with a 'create new' button. The footer of the page features four columns: 'Connect', 'Explore', 'Shop', and 'About', each providing additional information and links.

Εικόνα 4.1. Η ύποπτη ιστοσελίδα

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Έρευνα από το web εργαλείο

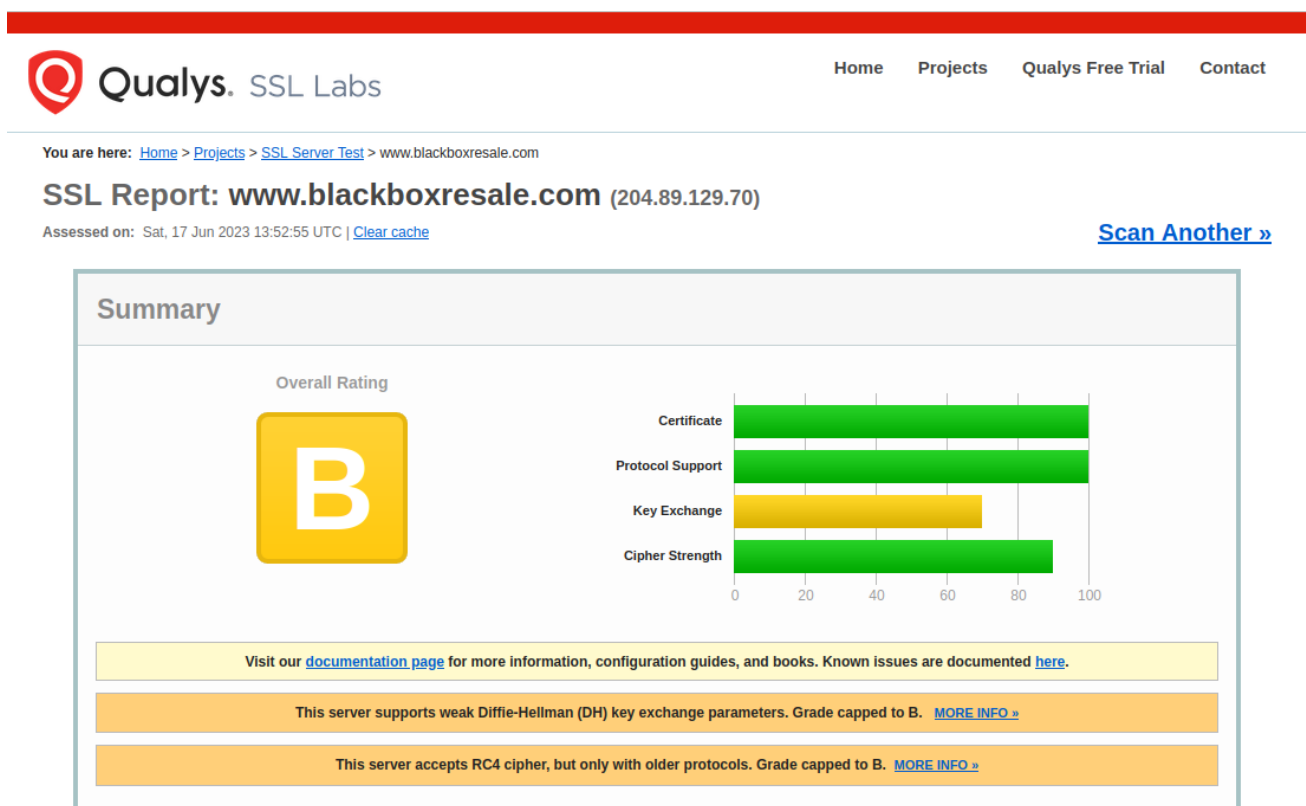
Αρχικά, χρησιμοποιήσαμε το web εργαλείο <https://www.ssllabs.com/ssltest/>.



The screenshot shows the Qualys SSL Labs website. The header includes the Qualys logo and navigation links: Home, Projects, Qualys Free Trial, and Contact. Below the header, a breadcrumb trail reads: You are here: Home > Projects > SSL Server Test. The main heading is "SSL Server Test". A paragraph explains the service: "This free online service performs a deep analysis of the configuration of any SSL web server on the public Internet. Please note that the information you submit here is used only to provide you the service. We don't use the domain names or the test results, and we never will." Below this is a form with a "Hostname:" label, a text input field, and a "Submit" button. A checkbox labeled "Do not show the results on the boards" is also present.

Εικόνα 4.2. Το web εργαλείο SSL Labs

Βάλαμε το URL της ιστοσελίδας στο πεδίο Hostname που παρέχει το εργαλείο και είδαμε τα αποτελέσματα της έρευνας και τα ψηφιακά πιστοποιητικά της ιστοσελίδας στο <https://www.ssllabs.com/ssltest/analyze.html?d=www.blackboxresale.com&fbclid=IwAR1eBgjHPYkoODEGkYQ8QZpCsFtKTJQ2H6Ws0XfFWynWe4zEwSQTUk2InMA>.



Εικόνα 4.3. Τα αποτελέσματα της έρευνας του web εργαλείου

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Certificate #1: RSA 2048 bits (SHA256withRSA)	
	Server Key and Certificate #1
	
Subject	blackboxresale.com Fingerprint SHA256: 18449296cf7bb82d47d73ed6feb2f8a82b43fb0d21fb31cd82fd88090acb1149 Pin SHA256: n3qjI4Jais/c8Z5pSCqqa7QlLMC6w1aEJYEuJec9N+Q=
Common names	blackboxresale.com
Alternative names	blackboxresale.com www.blackboxresale.com
Serial Number	2bf3c5d657423d7e
Valid from	Wed, 07 Sep 2022 22:55:50 UTC
Valid until	Thu, 07 Sep 2023 22:55:50 UTC (expires in 2 months and 20 days)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	Go Daddy Secure Certificate Authority - G2 AIA: http://certificates.godaddy.com/repository/gdig2.crt
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	CRL, OCSP CRL: http://crl.godaddy.com/gdig2s1-4470.crl OCSP: http://ocsp.godaddy.com/
Revocation status	Good (not revoked)
DNS CAA	No (more info)
Trusted	Yes Mozilla Apple Android Java Windows

Εικόνα 4.4. Το ψηφιακό πιστοποιητικό του server

Η έρευνα έδειξε ότι ο βαθμός αξιοπιστίας της ιστοσελίδας ως προς το πρωτόκολλο TLS είναι «B» που σημαίνει ότι παρουσιάζει ευπάθεια και συγκεκριμένα στο «Key Exchange» που είναι με κίτρινο χρώμα (σε αντίθεση με τα άλλα που είναι πράσινα στο ραβδόγραμμα δίπλα από τον βαθμό). Αναζητήσαμε περισσότερες πληροφορίες στα πεδία που λένε :

“The server supports weak Diffie-Hellman (DH) key exchange parameters. Grade capped to B. MORE INFO” και συγκεκριμένα στο άρθρο https://weakdh.org/?fbclid=IwAR1ozN1YuPSuKUzGyWoNb_grZ5nh-k3qyNUVWI_2oNXNOVCraxFz4eN9H-E

“This server accepts RC4 cipher, but only with older protocols. Grade capped to B. MORE INFO” και συγκεκριμένα στο άρθρο https://blog.qualys.com/product-tech/2013/03/19/rc4-in-tls-is-broken-now-what?_ga=2.217224725.2017122474.1687046115-1545449628.1687046115&fbclid=IwAR2bRWwSbZEd3dVnRd29X65jjsSRt2RPu5kiy6AZVza2QBukIcWXjJkL-1w

Weak Diffie-Hellman and the Logjam Attack

Diffie-Hellman key exchange is a popular cryptographic algorithm that allows Internet protocols to agree on a shared key and negotiate a secure connection. It is fundamental to many protocols including HTTPS, SSH, IPsec, SMTPS, and protocols that rely on TLS.

We have uncovered several weaknesses in how Diffie-Hellman key exchange has been deployed:

- 1. Logjam attack against the TLS protocol.** The Logjam attack allows a man-in-the-middle attacker to downgrade vulnerable TLS connections to 512-bit export-grade cryptography. This allows the attacker to read and modify any data passed over the connection. The attack is reminiscent of the [FREAK attack](#), but is due to a flaw in the TLS protocol rather than an implementation vulnerability, and attacks a Diffie-Hellman key exchange rather than an RSA key exchange. The attack affects any server that supports DHE_EXPORT ciphers, and affects all modern web browsers. 8.4% of the Top 1 Million domains were initially vulnerable.
- 2. Threats from state-level adversaries.** Millions of HTTPS, SSH, and VPN servers all use the same prime numbers for Diffie-Hellman key exchange. Practitioners believed this was safe as long as new key exchange messages were generated for every connection. However, the first step in the number field sieve—the most efficient algorithm for breaking a Diffie-Hellman connection—is dependent only on this prime. After this first step, an attacker can quickly break individual connections.

We carried out this computation against the most common 512-bit prime used for TLS and demonstrate that the Logjam attack can be used to downgrade connections to 80% of TLS servers supporting DHE_EXPORT. We further estimate that an academic team can break a 768-bit prime and that a nation-state can break a 1024-bit prime. Breaking the single, most common 1024-bit prime used by web servers would allow passive eavesdropping on connections to 18% of the Top 1 Million HTTPS domains. A second prime would allow passive decryption of connections to 66% of VPN servers and 26% of SSH servers. A close reading of published NSA leaks shows that the agency's attacks on VPNs are consistent with having achieved such a break.

Εικόνα 4.6. Πληροφορίες για την ευπάθεια της ιστοσελίδας στο πεδίο «Key Exchange»

[← Blog Home](#)

RC4 in TLS is Broken: Now What?



Ivan Ristic

March 19, 2013 - 4 min read

👍 10

Last updated on: December 15, 2022

RC4 has long been considered problematic, but until very recently there was no known way to exploit the weaknesses. After the BEAST attack was disclosed in 2011, we—grudgingly—started using RC4 in order to avoid the vulnerable CBC suites in TLS 1.0 and earlier. This caused the usage of RC4 to increase, and some say that it now accounts for about 50% of all TLS traffic.

Last week, a group of researchers (Nadhem AlFardan, Dan Bernstein, Kenny Paterson, Bertram Poettering and Jacob Schuld) [announced significant advancements in the attacks against RC4](#), unveiling new weaknesses as well as new methods to exploit them. Matthew Green has a [great overview](#) on his blog, and here are the [slides](#) from the talk where the new issues were announced.

At the moment, the attack is not yet practical because it requires access to millions and possibly billions of copies of the same data encrypted using different keys. A browser would have to make that many connections to a server to give the attacker enough data. A possible exploitation path is to somehow instrument the browser to make a large number of connections, while a man in the middle is observing and recording the traffic.

We are still safe at the moment, but there is a tremendous incentive for researchers to improve the attacks on RC4, which means that we need to act swiftly.

Εικόνα 4.7. Πληροφορίες για την ευπάθεια της ιστοσελίδας στο πεδίο «Key Exchange»

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ

Το άρθρο αναφέρει για ιστοσελίδες που υποστηρίζουν παλαιές εκδόσεις TLS που χρησιμοποιούν παλιούς κρυπτογραφικούς αλγορίθμους που έχουν ευπάθειες. Το αποτέλεσμα είναι να τεθεί σε κίνδυνο σημαντική πληροφορία που αφορά την επικοινωνία των πρωτοκόλλων.

Τέλος, είδαμε και την ανάλυση των εκδόσεων του πρωτοκόλλου και των κρυπτογραφικών σουιτών που υποστηρίζει η συγκεκριμένη ιστοσελίδα.

 Protocols	
TLS 1.3	No
TLS 1.2	Yes
TLS 1.1	No
TLS 1.0	No
SSL 3	No
SSL 2	No
  Cipher Suites	
# TLS 1.2 (suites in server-preferred order)	
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (0xc028) ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	256
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027) ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	128
TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014) ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	256
TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013) ECDH secp256r1 (eq. 3072 bits RSA) FS WEAK	128
TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 (0x9f) DH 1024 bits FS WEAK	256
TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 (0x9e) DH 1024 bits FS WEAK	128
TLS_RSA_WITH_AES_256_GCM_SHA384 (0x9d) WEAK	256
TLS_RSA_WITH_AES_128_GCM_SHA256 (0x9c) WEAK	128
TLS_RSA_WITH_AES_256_CBC_SHA256 (0x3d) WEAK	256
TLS_RSA_WITH_AES_128_CBC_SHA256 (0x3c) WEAK	128
TLS_RSA_WITH_AES_256_CBC_SHA (0x35) WEAK	256
TLS_RSA_WITH_AES_128_CBC_SHA (0x2f) WEAK	128
TLS_RSA_WITH_RC4_128_SHA (0x5) INSECURE	128
TLS_RSA_WITH_RC4_128_MD5 (0x4) INSECURE	128

Εικόνα 4.8. Ανάλυση των εκδόσεων του πρωτοκόλλου και των κρυπτογραφικών σουιτών

 Protocol Details	
Unable to perform this test due to an internal error. (1) For a better understanding of this test, please read this longer explanation (2) Key usage data kindly provided by the Censys network search engine; original DROWN website here (3) Censys data is only indicative of possible key and certificate reuse; possibly out-of-date and not complete	
DROWN	INTERNAL ERROR: connect timed out INTERNAL ERROR: connect timed out
Secure Renegotiation	Supported
Secure Client-Initiated Renegotiation	No
Insecure Client-Initiated Renegotiation	No
BEAST attack	Mitigated server-side (more info)
POODLE (SSLv3)	No, SSL 3 not supported (more info)
POODLE (TLS)	No (more info)
Zombie POODLE	No (more info) TLS 1.2 : 0xc027
GOLDENDOODLE	No (more info) TLS 1.2 : 0xc027
OpenSSL 0-Length	No (more info) TLS 1.2 : 0xc027
Sleeping POODLE	No (more info) TLS 1.2 : 0xc027
Downgrade attack prevention	Unknown (requires support for at least two protocols, excl. SSL2)
SSL/TLS compression	No
RC4	Yes INSECURE (more info)
Heartbeat (extension)	No
Heartbleed (vulnerability)	No (more info)
Ticketbleed (vulnerability)	No (more info)
OpenSSL CCS vuln. (CVE-2014-0224)	No (more info)
OpenSSL Padding Oracle vuln. (CVE-2016-2107)	No (more info)
ROBOT (vulnerability)	No (more info)
Forward Secrecy	Weak key exchange WEAK
ALPN	No
NPN	No
Session resumption (caching)	No (IDs assigned but not accepted)
Session resumption (tickets)	No
OCSP stapling	Yes

Εικόνα 4.9. Ανάλυση των λεπτομεριών του πρωτοκόλλου

Στην παραπάνω εικόνα επιβεβαιώνεται ότι πράγματι γίνεται διαρροή προσωπικών δεδομένων στο ίδιο χρονικό διάστημα από την είσοδο των χρηστών σε αυτή την ιστοσελίδα, καθώς ο κρυπτογραφικός αλγόριθμος RC4 δεν είναι πλέον ασφαλής.

Έρευνα από το εγκατεστημένο εργαλείο

Αρχικά, ανοίξαμε το τερματικό της μηχανής και μεταφερθήκαμε στον κατάλογο που βρίσκεται το python2 script με την εντολή

```
cd a2sv
```

Από την Εικόνα 4.3, πήραμε την IP Address της ιστοσελίδας και την βάλαμε ως παράμετρο για να τρέξουμε την εντολή :

```
python2 a2sv.py -t 204.89.129.70
```

Στη συνέχεια, είδαμε τα αποτελέσματα της έρευνας.

```
GREEN
[INF] Check the SSL..
[RES] This target supports SSL..
[INF] Scan Anonymous Cipher..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection
- [LOG] Analysis SSL Information
- [LOG] 'Connection success'
[INF] Scan CRIME(SPDY)..
- [LOG] IP Check Ok.
- [LOG] Start SSL Connection
- [LOG] Analysis SSL Information
- [LOG] 'Includes SPDY version <4'
[INF] Scan CCS Injection..
- [LOG] [TLSv1.2] 204.89.129.70:443 Invalid handshake.
- [LOG] [TLSv1.1] 204.89.129.70:443 Invalid handshake.
- [LOG] [TLSv1] 204.89.129.70:443 Invalid handshake.
- [LOG] [SSLv3] 204.89.129.70:443 Invalid handshake.
[INF] Scan HeartBleed..
- [LOG] Sending Client Hello...
- [LOG] Waiting for Server Hello...
Traceback (most recent call last):
  File "../a2sv/a2sv.py", line 421, in <module>
    runScan(checkVun)
  File "../a2sv/a2sv.py", line 177, in runScan
    heartbleed_result = m_heartbleed_run(targetIP,port,displayMode)
  File "/home/tiger/a2sv/module/M_heartbleed.py", line 196, in m_heartbleed_run
    check(target,port,"","","",displayMode)
  File "/home/tiger/a2sv/module/M_heartbleed.py", line 172, in check
    version = parseresp(s)
  File "/home/tiger/a2sv/module/M_heartbleed.py", line 136, in parseresp
    typ, ver, pay = recvmsg(s)
  File "/home/tiger/a2sv/module/M_heartbleed.py", line 83, in recvmsg
    hdr = recvall(s, 5)
  File "/home/tiger/a2sv/module/M_heartbleed.py", line 74, in recvall
    data = s.recv(remain)
socket.error: [Errno 104] Connection reset by peer
```

Εικόνα 4.9. Τα αποτελέσματα της συνοπτικής έρευνας του εγκατεστημένου εργαλείου

Η έρευνα έδειξε ότι ο server δεν ανταποκρίνεται στο Heartbeat Request που στέλνει ο client με αποτέλεσμα να διακόπτεται η SSL/TLS σύνδεση (εξού και το σφάλμα socket.error).

Συμφωνίες και διαφωνίες των εργαλείων

Το web εργαλείο πραγματοποιεί εκτενέστερους ελέγχους από το εγκατεστημένο, αλλά παρόλα αυτά συμφωνούν και τα δύο εργαλεία ότι η ιστοσελίδα έχει ευπάθειες λόγω το ότι υποστηρίζει παλαιότερες εκδόσεις του TLS. Ωστόσο, το εγκατεστημένο εργαλείο δεν εντοπίζει την ευπάθεια όσον αφορά την ανασφάλεια του κρυπτογραφικού αλγορίθμου RC4.

ΑΣΦΑΛΕΙΑ ΣΤΗΝ ΤΕΧΝΟΛΟΓΙΑ ΤΗΣ ΠΛΗΡΟΦΟΡΙΑΣ



Σας ευχαριστώ για την προσοχή σας.

